Information Systems Security

Arrianto Mukti Wibowo, M.Sc.,

Faculty of Computer Science
University of Indonesia

amwibowo@cs.ui.ac.id

System & Application Development

Tujuan

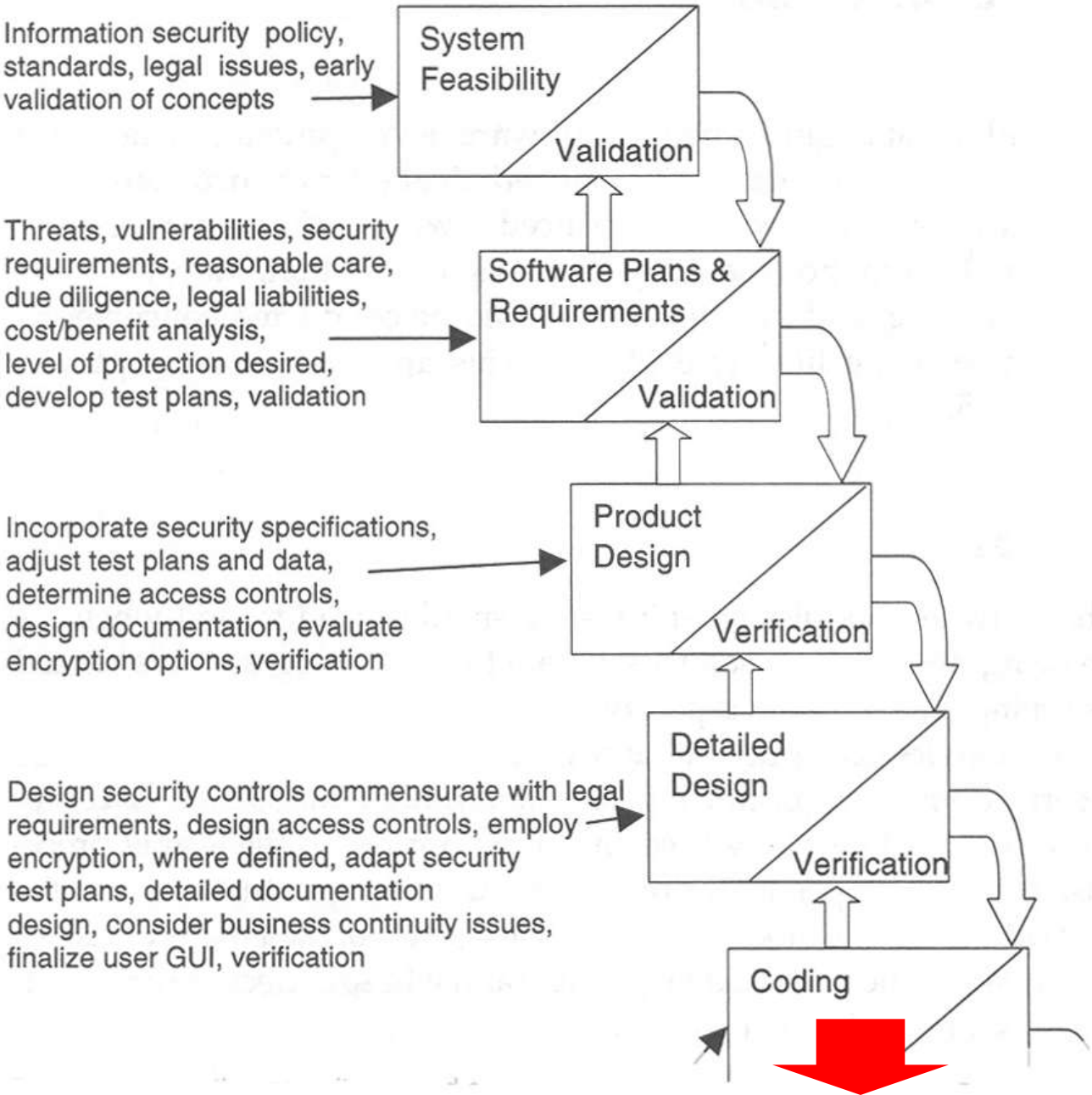
- Mempelajari berbagai aspek keamanan dan kontrol-kontrol yang terkait pada pengembangan sistem informasi.

Topik

- Complexity of functionality, data, database management security, systems development life cycle, application development methodology, software change control, malicious code

Information Security and the Life Cycle Model

- The earlier in the process a component is introduced, the better chance for success. Information security is no different.
- Information security controls conception, development, implementation, testing, and maintenance .
- Info sec. controls should be part of the feasibility phase.

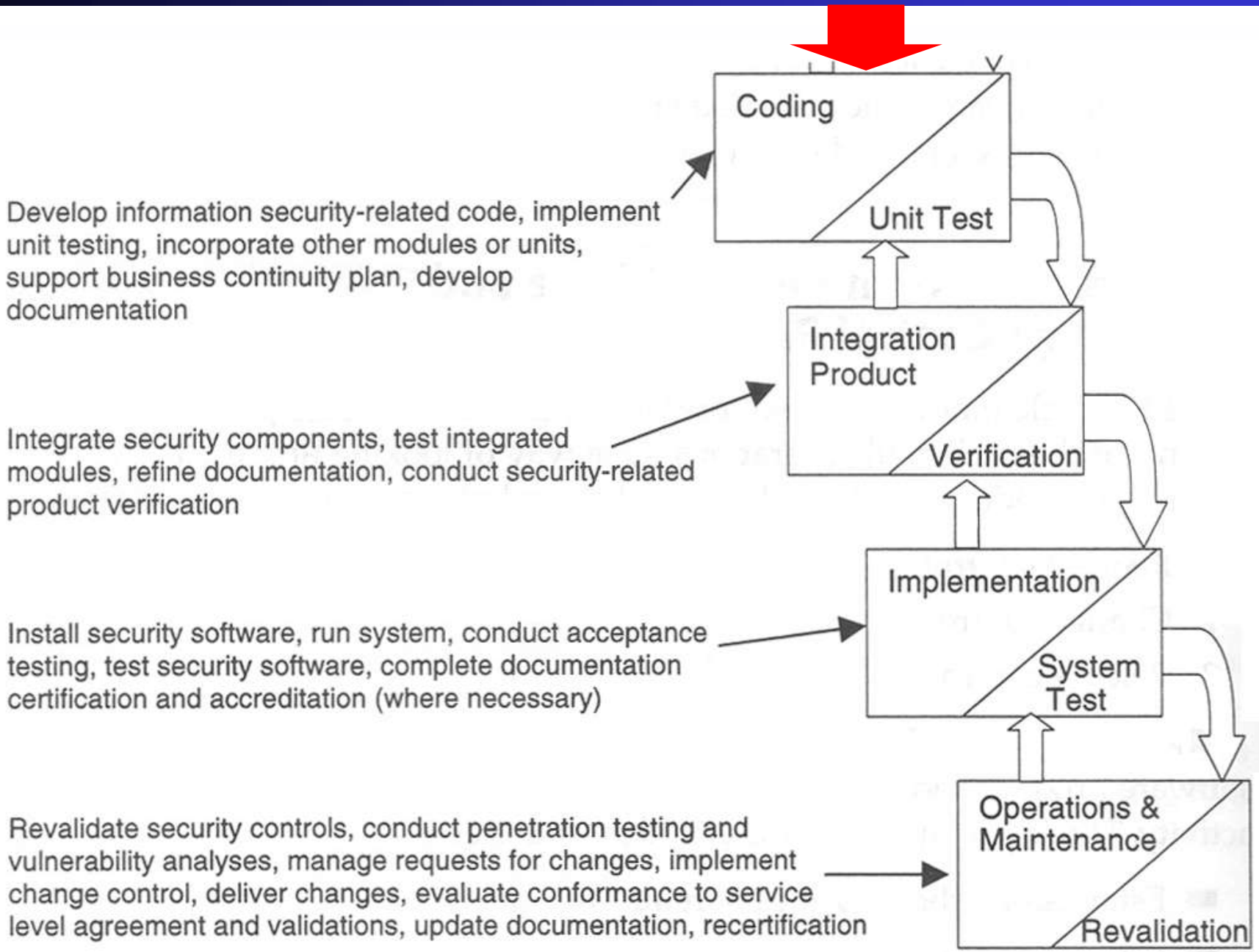

Information security policy, standards, legal issues, early validation of concepts
System Feasibility
Validation
Threats, vulnerabilities, security requirements, reasonable care, due diligence, legal liabilities, cost/benefit analysis, level of protection desired, develop test plans, validation
Software Plans & Requirements
Validation
Incorporate security specifications, adjust test plans and data, determine access controls, design documentation, evaluate encryption options, verification
Product Design
Verification
Design security controls commensurate with legal requirements, design access controls, employ encryption, where defined, adapt security test plans, detailed documentation design, consider business continuity issues, finalize user GUI, verification
Detailed Design
Verification
Coding

Validasi & Verifikasi

- Validasi
  - Are we bulilding the right thing?
    "Substantiation that a software, within its domain of applicability, possesses a satisfactory range of accuracy consistent with the intended application of the software" (software vs. actual)
- Verifikasi
  - Are we building it right?
  - Misalnya: perecanaan & pelaksanaan pengujian, penempatan kendali/kontrol, dsb.

Pertanyaan

- Apa yang anda lihat sebagai celah keamanan pada tahap ini?
- Apa yang dapat membahayakan / mengancam sistem?


Coding
Unit Test
Develop information security-related code, implement unit testing, incorporate other modules or units, support business continuity plan, develop documentation
Integration
Product
Verification
Integrate security components, test integrated modules, refine documentation, conduct security-related product verification
Implementation
System Test
Install security software, run system, conduct acceptance testing, test security software, complete documentation certification and accreditation (where necessary)
Operations & Maintenance
Revalidation
Revalidate security controls, conduct penetration testing and vulnerability analyses, manage requests for changes, implement change control, deliver changes, evaluate conformance to service level agreement and validations, update documentation, recertification

Testing Issues

- Testing of the software modules or unit testing should be addressed when the modules are being designed.
- Personnel SEPARATE from the programmers should conduct this testing.
- Testing should check modules using normal and valid input data, and also check for incorrect types, out of range values, and other bounds.
- Use TEST DATA, out of range values, and incorrect module types

TEST SCRIPT
Software XYZ

TEST CASE No :	1
TEST CASE DESCRIPTION :	Service test
TEST DATE :	Agustus 2004

Step No :	Step Description	Input Data	Expected Result	Actual Result			Remark
				Pass	Fail	Dfct No	
	Login						
	User ID	bu					
	Password	bu	**				
	Jenis login	Business Unit	masuk sebagai BU				
	Select Project						
	Open existing project						
	Open from existing directory						
	Create new project	pilih	masuk dialog				
			company info				
	Company Information						
	Company / debtor	PT Hotel					
	Customer registration number	12345					
	Project title	penambahan kamar					
	Credit aplication serial number	456789					
	Group	Group Wisata Indonesia					
	Address	Jl.Jend.Sudirman					
	Business Field	Pariwisata					
	Project Location	Jakarta					
	Project Purpose	menambah kapasitas					
	Existing Fascilities	0					
		OK					

Software maintenance phase

- Request control
- Change control
- Release control

Request Control

- Kendali terhadap permohonan dari user untuk perubahan
- Mencakup:
  - Pembuatan prioritas permohonan
  - Estimasi biaya perbaikan/ perubahan
  - Memvalidasi user interface kepada user

Change Control

- Permasalahan yang ditangani antara lain:
  - Merekonstruksi problem
  - Menganalisa permasalahan
  - Melakukan perbaikan/perubahan
  - Pengujian
  - Melakukan kontrol kualitas
- Hal lain yang perlu diperhatikan:
  - Pendokumentasian perbaikan
  - Apakah ada dampak pada modul lainnya yang terkait?
  - Akreditasi dan sertifikasi ulang, jika perlu…

Release Control

- Apa (modul mana) yang akhirnya dimasukkan dalam software versi rilis
- Pengarsipan rilis software
- User acceptance testing
- Pendistribusian software rilis terbaru tsb
- Configuration management

Pertanyaan

- Apa yang anda lihat sebagai celah keamanan pada tahap ini?
- Apa yang dapat membahayakan / mengancam sistem?

Configuration Management

- In order to manage evolving changes to software products and formally track and issue new versions of software, configuration management is employed.
- Configuration Management is the discipline of identifying the components of a continually evolving system for the purposes of controlling changes to those components and maintaing integrity and tractability throughout the cycle.

Configuration Procedure

1. identify and document the functional and physical characteristics of each configuration item (configuration identification)
2. control changes to the configuration items and issue versions of configuration items from the software library (configuration control)
3. record the processing of changes (configuration status accounting)
4. control the quality of the configuration management procedures (configuration audit)

Software Capability Maturity Model (CMM)

- The software CMM is based on the premise that the quality of a software product is a direct function of the quality of its associated software development and maintenance processes. A "process" (according to Software Engineering Institute / SEI), is a set of activities, methods, practices, and transformations that people use to develop and maintain systems and associated products.
- The software CMM was first developed by the SEI in 1986. The SEI defines five maturity levels that server as a foundation for conducting continuous process improvement and as an ordinal scale for measuring the maturity of the organization involved in the software processes.

Level CMM

- **Level 1 initiating-**competent people and heroics ; processes are informal and ad hoc
- **Level 2 repeatable-**project management processes ; project management practices are institutionalized
- **Level 3 defined-**engineering processes and organizational support ; technical practices are integrated with management practices institutionalized.
- **Level 4 managed** product and process improvement ; product and process are quantitatively controlled
- **Level 5 optimizing-**continuous process improvement ; process improvement is institutionalized

Generic Maturity Model - Dimensions

	UNDERSTANDING AND AWARENESS	TRAINING AND COMMUNICATION	PROCESS AND PRACTICES	TECHNIQUES AND AUTOMATION	COMPLIANCE	EXPERTISE
1	recognition	sporadic communication on the issues	ad hoc approaches to process and practices			
2	awareness	communication on the overall issue and need	similar/common processes emerge; largely intuitive	common tools are emerging	inconsistent monitoring in isolated areas	
3	understand need to act	informal training supports individual initiative	existing practices defined, standardised and documented; sharing of the better practices	currently available techniques are used; minimum practices are enforced; tool-set becomes standardised	inconsistent monitoring globally; measurement processes emerge; IT Balanced Scorecard ideas are being adopted; occasional intuitive application of root cause analysis	involvement of IT specialists
4	understand full requirements	formal training supports a managed program	process ownership and responsibilities assigned; process is sound and complete; internal best practices applied;	mature techniques applied; standard tools enforced; limited, tactical use of technology	IT Balanced Scorecards implemented in some areas with exceptions noted by management; root cause analysis being standardised	involvement of all internal domain experts
5	advanced forward-looking understanding	training and communications supports external best practices and use of leading edge concepts/techniques	best external practices applied	sophisticated techniques are deployed; extensive, optimised use of technology	global application of IT Balance Scorecard and exceptions are globally and consistently noted by management; root cause analysis consistently applied	use of external experts and industry leaders for guidance

Pertanyaan

- Apa yang anda lihat sebagai celah keamanan pada tahap ini?
- Apa yang dapat membahayakan / mengancam sistem?

Application Controls

- The goal is to enforce the organizations security policy and procedures and to maintain the confidentiality, integrity, and availability.
- Users running applications require the availability of the system.
- A service level agreement guarantees the quality of a service to a subscriber by an ISP

Application Control Types

APPLICATION CONTROL TYPE	ACCURACY	SECURITY	CONSISTENCY
Preventive	Data checks, forms, custom screens, validity checks, contingency planning, and backups.	Firewalls, reference monitors, sensitivity labels, traffic padding, encryption, data classification, one-time passwords, contingency planning, separation of development, application and test environments.	Data dictionary, programming standards, and database management system.
Detective	Cyclic redundancy checks, structured walk-throughs, hash totals, and reasonableness checks.	Intrusion detection systems and audit trails.	Comparison controls, relationship tests, and reconciliation controls.
Corrective	Backups, control reports, before/after imaging reporting, and checkpoint restarts.	Emergency response and reference monitor.	Program comments and database controls.

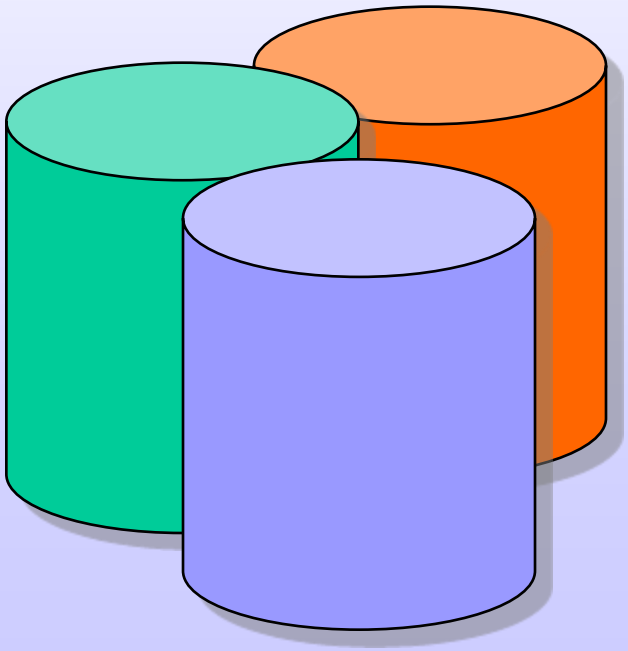
Application controls examples

- Line count & record count
- Field check: apakah tipe datanya benar
- Sign check
- Validity check: lookup to existing data, e.g. customer ID
- Limit check: misalnya tidak mungkin kurang/melebihi angka tertentu
- Range check: pasti punya batas atas dan bawah, misalnya tanggal
- Reasonableness test: logical correctness of the input. Misalnya kenaikan gaji $1500 merupakan hal yang wajar bagi eksekutif dg gaji $13000, tapi aneh buat seorang janitor dengan gaji $1000

- Prompting
- Preformatting
- Completeness check
- Closed loop verification, misalnya dalam mengecek nomor bank account dengan nama orangnya
- Error message

Database Security

- Views
- OLAP
- Aggregation
- Inference

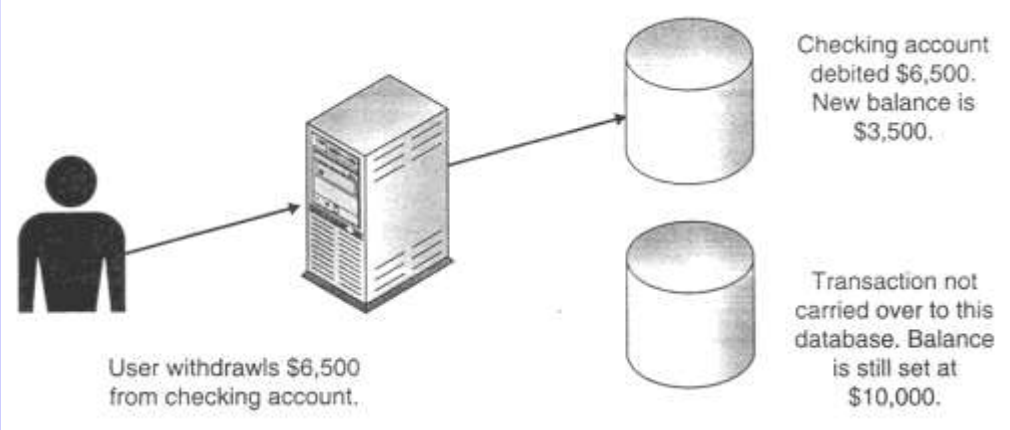


View

- Tiap user memiliki hak akes data tertentu dan terbatas

On-Line Transaction Processing Security

- Kalau suatu proses terhenti karena suatu hal, OLTP bisa berusaha merestart proses
- Jika tidak bisa, maka transaksi akan di-rollback, sehingga tidak ada pencatatan sebagian
- Anomali ini dicatat di log komputer
- Contoh: pemindahbukuan dari satu nasabah ke nasabah lainnya
- Two-phase commit OLTP: memastikan transaksi pada satu database akan tercermin pula pada database lainnya, sebelum transaksi dianggap selesai



Aggregation

- Def: Act of combining information from separate sources.
- The combination of the information forms new information, which the subject does not have the nececssary rights to access.
- The combined information has a sensivity that is greater than the individual parts

Aggregation example

- Suppose the DB-Admin has a secret data "The quick brown fox jumps over the fence"
- And divided the sentence into several components:

A	The	B	quick	C	brown fox
D	jumps	E	over	F	the fence

- User X is allowed to read A, C, F
- If user X is intelligent, X can guess!

Inference

- Def: Ability to derive information that is not explicitly available
- Contoh:
  - Seorang perwira rendah data entry tidak punya akses ke data pergerakan pasukan tempur
  - Tapi punya data mengenai bahan makanan spesifik untuk pasukan tempur (apa dan musti didrop di mana) yang berkemah.
  - Dia bisa menduga pergerakan pasukan tempur